DETECTION THREAT LANDSCAPE

Web/PHP Worker
Suspicious Child Execution

Behavioral hunting dossier for PHP core RCE post-exploitation coverage

Classification Hunting query	**Confidence** Medium
Primary platform Defender XDR	**Date** 22 October 2026

Analytical boundary

Untested implementation sketch. A match does not identify CVE-2026-109618 or CVE-2026-109619 and does not prove exploitation, compromise or attribution.

php-fpm → bash / curl / wget → review lineage

02 EXECUTIVE ASSESSMENT

Executive Assessment

Operational value: 8 / 10

Durable visibility into a convergent consequence of web RCE, independent of the initial exploit string.

Decision: hunt, do not alert yet

No in-the-wild exploitation was established at publication. Controlled testing and local overlap measurement are required.

Confirmed

PHP published fixed releases for two unauthenticated PHP-core RCE vulnerabilities. Elastic documented web/PHP-parent process behavior and a controlled PHP-FPM diagnostic.

Interpretation

The defensible detection surface is the post-exploitation child process, not a CVE-specific request signature.

Assumptions

MDE captures Linux process events, full command line and direct initiating process. Containers and wrappers may break lineage.

03 THREAT MECHANICS

Behavior and Boundaries

Official PHP advisory	Two critical unauthenticated RCE flaws; fixed versions published.	That a process event came from either CVE.
Elastic research	Web/PHP parents can spawn shells, interpreters, downloaders or reverse-shell helpers after RCE.	Active exploitation or attribution.
Defender telemetry	Parent, child and command line can be inspected in one event.	HTTP request, memory corruption or exploit success.

Analytical boundary

This dossier detects possible post-exploitation behavior. It is not an exploit detector, vulnerability scanner or compromise verdict.

04 TELEMETRY & EVIDENCE

Telemetry Model

Required telemetry

DeviceProcessEvents from Microsoft Defender for Endpoint on Linux with direct parent, child image and full command line.

Optional enrichment

PHP inventory, web/PHP logs, container metadata, network events and web-root file events.

Timestamp, DeviceId, DeviceName	Documented	Event and host identity
InitiatingProcessFileName	Documented; population environment-dependent	Web/PHP parent
FileName, ProcessCommandLine	Documented; population environment-dependent	Child behavior and grammar
AccountName, SHA1, ReportId	Documented	Investigation context

Unavailable from this hunt

HTTP payload, memory corruption, exploit success, PHP configuration, file contents and attribution.

05 DETECTION LOGIC

Primary Hunting Query

Status

Hunting query - Untested implementation sketch. Single-table logic; no join, sequence, count, rarity score or maliciousness threshold.

```
// Hunting query - Untested implementation sketch
// Purpose: surface a PHP/web-server process starting a shell or high-risk utility
// in a command shape consistent with post-exploitation after web RCE.
// A match does NOT identify CVE-2026-109618/CVE-2026-109619, prove exploitation,
// or establish malicious intent. Validate on Linux hosts onboarded to MDE.
DeviceProcessEvents
| where Timestamp > ago(7d)
| where InitiatingProcessFileName in~ ("apache2", "httpd", "nginx", "php-cgi")
    or InitiatingProcessFileName startswith "php-fpm"
    or InitiatingProcessFileName startswith "lsphp"
| where
    (
        FileName in~ ("bash", "dash", "sh", "zsh", "ksh")
        and ProcessCommandLine has_any
            ("/dev/tcp/", "base64 -d", "curl ", "wget ", "/etc/shadow",
             "mkfifo", "nc ", "socat", "whoami", "hostname", "uname -a")
    )
    or FileName in~ ("curl", "wget", "nc", "socat")
    or (
        FileName in~ ("python", "python3", "perl", "ruby", "node", "php")
        and ProcessCommandLine has_any (" -c ", " -e ", " -r ")
    )
| project Timestamp, DeviceId, DeviceName, AccountName,
          InitiatingProcessFileName, InitiatingProcessCommandLine,
          FileName, FolderPath, ProcessCommandLine, SHA1, ReportId
| order by Timestamp desc
```

06 TRIAGE & INVESTIGATION

Investigation Workflow

01

Confirm host role, PHP runtime, internet exposure and patch level.

02

Validate direct lineage and retain the raw event; inspect wrappers and containers.

03

Classify the command grammar: discovery, download, staging, reverse shell or approved diagnostic.

04

Pivot to network, files, web logs, web-root changes, persistence, accounts and credentials.

05

Escalate only with corroborating evidence; otherwise document and tune the exact legitimate grammar.

Insufficient evidence

A lone whoami, utility filename or web-server parent without contextual review.

07 FALSE POSITIVES & VALIDATION

Promotion Gate

Deployment or plugin hooks	Medium	Verified app + exact grammar + host scope
Monitoring / health checks	Medium	Owner-approved executable and command
Support diagnostics / scanners	High	Test window, asset and operator
Red team	Low	Preserve for validation metrics

Validation sequence

1. Check field coverage. 2. Run approved PHP-FPM to whoami. 3. Measure seven-day overlap. 4. Test container and wrapper cases.

Promotion criteria

Stable lineage, complete command lines, bounded legitimate activity, documented exclusions and a reproducible controlled test.

Reject if

Routine application behavior dominates or parent-child direction is unreliable.

08 CONCLUSION & REFERENCES

Conclusion, ATT&CK; and References

T1190 · vulnerability context

Exploit Public-Facing Application is supported by the confirmed PHP vulnerabilities; it is not directly observed by this process query.

T1059 · observed behavior

Command and Scripting Interpreter is supported when the event shows a shell or interpreter child.

Conclusion

This hunt is a defensible, reusable way to surface suspicious child execution from PHP and web-server processes. Its value is behavioral and cross-vulnerability. It must remain a hunting lead until local coverage and benign overlap are measured.

References

Elastic Security Labs, 21 Oct 2026
elastic.co/security-labs/threat-command/php2shell-php-rce-detection

PHP Security Advisory, 21 Oct 2026
php.net/archive/2026.php#2026-10-21-1

Microsoft Defender XDR DeviceProcessEvents schema, updated 7 Aug 2026

MITRE ATT&CK; T1190

Residual risk

Fileless execution within the worker, missing sensor coverage, containers, wrapper processes and truncated command lines can evade this hunt.